I. PURPOSE

This policy establishes controls related to security awareness and training. The policy provides guidance in decision-making and practices that optimize resources, mitigate risk, and maximize return on investment.

II. DEFINITIONS

"Awareness" – means being informed of security policies and associated controls and guidelines.

"Compliance" - means adherence to the minimum guidelines outlined in this policy.

"Training" - means informing users of specific rules and guidelines to remain compliant with security policies.

III. POLICY

The Commonwealth Office of Technology (COT) and other enterprise agencies with Information Technology (IT) systems in the Commonwealth's infrastructure shall ensure proper security awareness and training. They shall adhere to, at a minimum, the moderate-level control standards outlined in the National Institute of Standards and Technology (NIST) Special Publication 800-53 Rev 5 Security Awareness and Training (AT) control family in accordance with CIO-091 Enterprise Information Security Program.

For details on COT-approved controls, refer to the Office of the Chief Information Security Officer's (CISO) ENT-201 Enterprise Security Controls and Best Practices.

IV. CORRECTIVE OR DISCIPLINARY ACTION

Each agency shall ensure that all relevant staff within their organizational authority are aware of and comply with this policy. The agency is responsible for enforcing it. Unauthorized and/or neglectful actions regarding this policy may result in disciplinary action up to and including dismissal. COT may require additional service charges for remediation efforts due to non-compliance with this policy.

V. APPLICABILITY

All executive branch agencies and non-executive branch agencies using COT-managed infrastructure or services shall adhere to this policy. This includes employees, contractors, consultants, temporaries, volunteers, and other workers within state government.

Organizations may modify this policy to fulfill their responsibilities but must obtain approval through an exception request. Staff should refer to their internal policy that may have additional information or clarification.

VI. REFERENCES

Helpful references can be found on the Enterprise IT Policies webpage.